# Plan ante incidentes de seguridad

Filtración, acceso indebido o pérdida de datos · Piloto de Puente en [ESCUELA]

**BORRADOR — revisar con un abogado antes de usar.**

**Para quién es:** el equipo técnico de Puente, la dirección de [ESCUELA] y [RESPONSABLE DEL TRATAMIENTO].

**Por qué existe:** la ley obliga a tomar medidas para evitar que los datos se adulteren, se pierdan o se consulten sin permiso, y para **detectar** esos desvíos (Ley 25.326, art. 9). La AAIP recomienda tener un proceso de incidentes que cubra detección, evaluación, contención, respuesta, escalamiento y corrección (Resolución AAIP 47/2018, anexo I, punto G). La ley no fija hoy un plazo obligatorio para notificar incidentes; los plazos de abajo son **compromisos propios** del piloto.

## 1. Quién hace qué

| Rol | Persona | Contacto |
|---|---|---|
| Responsable técnico de Puente (coordina el incidente) | [NOMBRE] | [CONTACTO] |
| Responsable del tratamiento | [RESPONSABLE DEL TRATAMIENTO] | [CONTACTO] |
| Dirección de la escuela | [NOMBRE DIRECTIVO] | [CONTACTO ESCUELA] |
| Asesoría legal | [ABOGADO/A] | [CONTACTO] |
| Suplente técnico (si el titular no responde en 2 h) | [NOMBRE] | [CONTACTO] |

## 2. Qué cuenta como incidente

- Alguien vio datos que no le correspondían (una familia ve a otro chico, una docente ve alumnos no asignados).
- Una cuenta fue usada por otra persona (código compartido, mail hackeado, celular perdido con sesión abierta).
- Se filtró una clave o token (por ejemplo, publicado en un chat, en el repositorio o en un log).
- Se mandaron mails a la persona equivocada.
- Una planilla con datos reales quedó en una compu o carpeta compartida.
- Datos borrados o modificados sin querer, o caída que hizo perder información.
- Un proveedor (Vercel, Neon, Resend, OpenRouter) informa un incidente que puede afectar a Puente.
- Muchos intentos fallidos de ingreso o tráfico raro.

**Ante la duda, se trata como incidente.**

## 3. Pasos y plazos

Los plazos corren desde que alguien de Puente o de la escuela **se entera**.

**Paso 1. Detectar y registrar (enseguida)**

- Cualquiera que lo note avisa a la dirección y al responsable técnico por [CONTACTO], **en el día**.
- El responsable técnico abre una entrada en el **registro de incidentes** (punto 5) con fecha, hora y quién avisó.
- **No borrar nada** que sirva para entender qué pasó (logs, mails, capturas).

**Paso 2. Contener (dentro de las primeras 4 horas)**

Elegir lo que corresponda:

- **Cortar sesiones:** rotar `SESSION_SECRET` en Vercel y volver a desplegar (invalida todas las sesiones) o borrar las sesiones afectadas en la tabla `sesiones`.
- **Desactivar cuentas:** desactivar la docente afectada desde *Panel* → *Docentes*; quitar el email de una familia de la ficha (pierde el acceso); en casos graves, **desactivar la escuela** desde *Panel* → *Escuelas* (corta las sesiones de sus docentes y nadie recibe códigos).
- **Rotar claves:** contraseña de la base en Neon (y actualizar `DATABASE_URL`), `RESEND_API_KEY`, `OPENROUTER_API_KEY`, token de Vercel Blob, tokens de Vercel y cualquier otra credencial expuesta. Revisar que no queden copias en el repositorio.
- **Frenar el tráfico:** activar el modo *challenge/deny* del Firewall de Vercel o poner la app en mantenimiento.

- **Pedir la baja** de mails o archivos enviados por error (pedirle a quien los recibió que los borre y lo confirme por escrito).
- **Resguardar evidencia:** exportar los logs de Vercel y Neon del período.

**Paso 3. Evaluar (dentro de las 24 horas)**

Responder por escrito:

1. ¿Qué datos se vieron afectados? (fichas, días, chat, emails, teléfonos)
2. ¿De cuántos alumnos y familias? ¿Quiénes?
3. ¿Quién accedió y durante cuánto tiempo?
4. ¿Hubo datos sensibles (apoyos, sensibilidades, alertas)?
5. ¿Sigue abierto el problema o ya está contenido?
6. **Riesgo:** bajo (por ejemplo, un error interno ya corregido, sin datos vistos por terceros), medio o alto (datos de chicos vistos por personas ajenas, o publicados).

**Paso 4. Avisar**

| A quién | Cuándo | Cómo |
|---|---|---|
| Dirección de la escuela y responsable del tratamiento | Dentro de las **24 h** de confirmado | Llamado y mail |
| Familias afectadas | Dentro de las **72 h** de confirmado, si el riesgo es medio o alto (o antes si deben actuar, por ejemplo cambiar la clave de su mail) | Lo decide la dirección: reunión, llamado o nota. Usar el modelo del punto 6 |
| Docentes | Cuando deban hacer algo (cerrar sesión, cambiar su clave de mail) | Mail |
| AAIP | Si el riesgo es medio o alto, se recomienda comunicarlo dentro de las **72 h**, a decisión del responsable del tratamiento y su asesoría legal | Mail a datospersonales@aaip.gob.ar |
| Supervisión / Ministerio | Si la escuela lo considera necesario o lo exige la normativa educativa | Nota de la dirección |
| Justicia | Si hubo acceso ilegítimo o robo de datos (Código Penal, art. 157 bis) | Denuncia penal, con asesoría legal |
| Proveedor afectado | Si el problema está en su servicio | Soporte del proveedor |

**Paso 5. Corregir y cerrar (dentro de los 15 días)**

- Arreglar la causa (código, configuración, procedimiento) y probar el arreglo.
- Restaurar datos desde la copia de seguridad de Neon (point-in-time restore) si se perdieron o alteraron.
- Completar el registro con lo aprendido y las mejoras.
- Contarles a la escuela y a las familias avisadas cómo se resolvió.
- Si el riesgo fue alto, evaluar con la escuela si el piloto sigue, se pausa o termina.

## 4. Prevención (antes de empezar el piloto)

- ☐ Base separada para pruebas (Preview) y producción.
- ☐ Copias de seguridad de Neon activadas y **una restauración de prueba** hecha.
- ☐ `SESSION_SECRET` largo y aleatorio; PIN de alta inicial fuerte y distinto del de demo.
- ☐ Firewall de Vercel en *challenge/deny* para bots.
- ☐ Lista actualizada de todas las claves y de dónde rotarlas.
- ☐ Registro de accesos de docentes y alertas de intentos fallidos.
- ☐ Remitente de mails en el dominio propio de Puente ([DOMINIO]).
- ☐ Contactos de este plan completos y probados.
- ☐ Simulacro de 30 minutos: “una familia ve a otro chico”. ¿Quién hace qué?

## 5. Registro de incidentes

Una ficha por incidente (en papel o planilla), guardada por el responsable del tratamiento. **No copiar en el registro los datos de los chicos**; alcanza con un identificador interno.

**Ficha de incidente** (copiar una por incidente):

**N.º de incidente:** _____

**Fecha y hora de detección:** _____

**Quién avisó y cómo:** _____

**Qué pasó:** _____

_____

**Datos afectados y cantidad de alumnos y familias:** _____

_____

**Riesgo (bajo / medio / alto) y por qué:** _____

**Contención: qué se hizo y cuándo:** _____

_____

**Avisos: a quién y cuándo:** _____

**Causa:** _____

**Corrección y mejoras:** _____

_____

**Fecha de cierre y firma:** _____

## 6. Modelo de aviso a familias

Hola, [nombre del adulto]. Te escribimos desde [ESCUELA] y Puente.

El [fecha] detectamos [qué pasó, en palabras simples: por ejemplo, “que una persona que no correspondía pudo ver el registro del día de algunos chicos”]. Entre los datos afectados están [qué datos] de [nombre de pila del chico o chica].

Lo que ya hicimos: [medidas: cortamos el acceso, cambiamos las claves, etc.].

Lo que te recomendamos: [si aplica: cambiar la contraseña de tu mail, no responder mails sospechosos].

Recordá que podés pedir ver, corregir o borrar tus datos, o retirar tu consentimiento, escribiendo a [CONTACTO].

Lamentamos mucho lo ocurrido. Para cualquier duda: [CONTACTO].

**Normas y guías citadas:** Ley 25.326 (art. 9 y art. 32, que incorpora el art. 157 bis al Código Penal); Resolución AAIP 47/2018, anexo I, punto G (Incidentes de seguridad).